

2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS

DYNACCOUNTIC

www.malware-traffic-analysis.net/2018/05/11/2018-05-11-traffic-analysis-exercise.pcap.zip

The zip file is password-protected with the standard password. See the "about" page of my site if you don't know it.

The associated network segment:

- LAN segment: 10.0.14.0/24 (10.0.14.0 through 10.0.14.255)
- Broadcast address: 10.0.14.255
- Domain controller: 10.0.14.3 (NIGHTDEW-DC)
- Domain: nightdew.org

REPORT GUIDELINES:

EXECUTIVE SUMMARY:

- Date/Time of the activity
- Who was infected
- What malware was involved

DETAILS:

- Infected user's IP address:
- Infected user's MAC address:
- Infected user's host name:
- Infected user's account name:

INDICATORS:

- List the IP addresses, ports, and domains associated with this activity.

ANSWERS

EXECUTIVE SUMMARY:

On Friday 2018-05-11 at 02:08 UTC, a Windows computer used by Faith Hoffman was infected with Hancitor and Zeus Panda Banker malware. This infection originated from malicious spam, which is a frequently-reported vector for Hancitor. The infected computer was sent to our help desk to be wiped and re-imaged. Faith Hoffman has changed all of his login credentials for any accounts he used on that computer.

DETAILS:

2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS

- IP address: 10.0.14.129
- MAC address: 00:1a:92:06:5c:7b
- Host name: CHICAGO-7FA3-PC
- User account name: faith.hoffman

INDICATORS:

- 185.43.223.6 port 80 - **lysedsohap.com** - POST /4/forum.php
- 111.90.144.30 port 80 - **wansaiful.com** - GET /wp-content/plugins/easy-media-download/1
- 111.90.144.30 port 80 - **wansaiful.com** - GET /wp-content/plugins/easy-media-download/2
- 111.90.144.30 port 80 - **wansaiful.com** - GET /wp-content/plugins/easy-media-download/3
- 185.43.223.6 port 80 - **lysedsohap.com** - POST /mlu/forum.php
- 185.43.223.6 port 80 - **lysedsohap.com** - POST /d2/about.php
- 185.174.175.14 port 443 - **robwassotdint.ru** - HTTPS/SSL/TLS traffic caused by Zeus Panda Banker

DETAILS

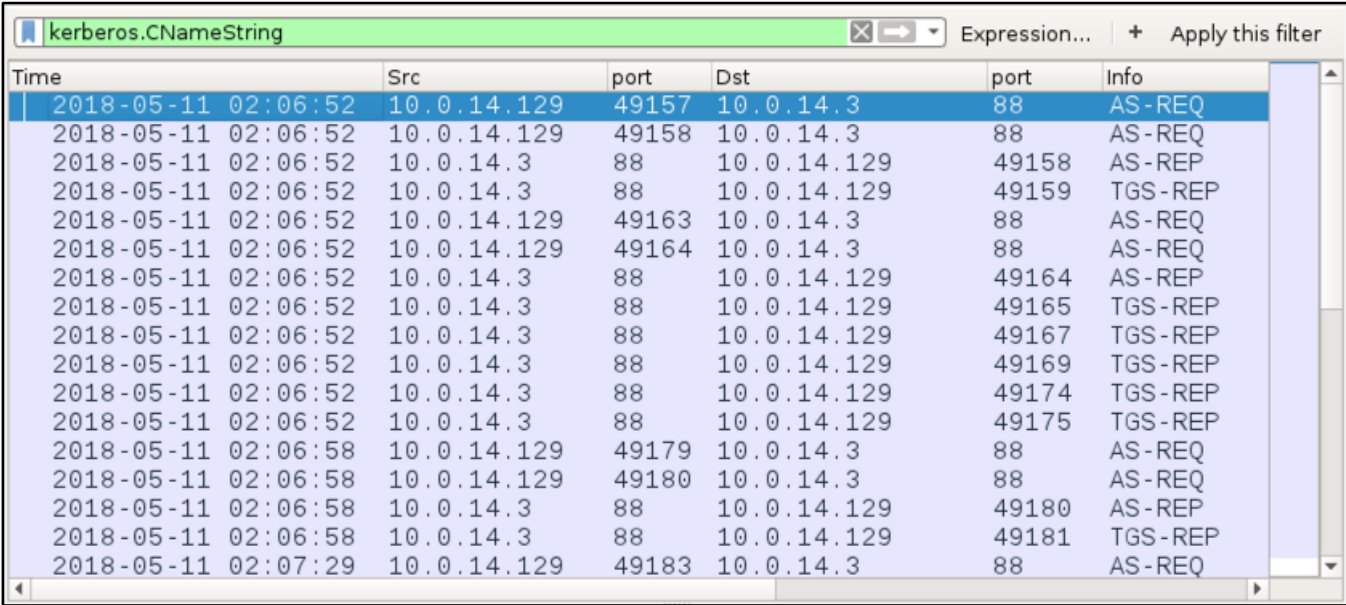
As always, I recommend you set up Wireshark according to the tutorials I've documented at:

- <http://malware-traffic-analysis.net/tutorials/index.html>

I submitted the pcap to both VirusTotal ([link](#)) and Packettotal ([link](#)). Packettotal didn't have anything immediately obvious, and VirusTotal didn't show any alerts at all.

First, let's get the host information from the exercise pcap. There are a number of ways you can do this, but the easiest for me is filtering on **Kerberos.CNameString** with a custom column that shows all of the CNameString values.

First, you need to filter on **Kerberos.CNameString**, which should give you the following results:



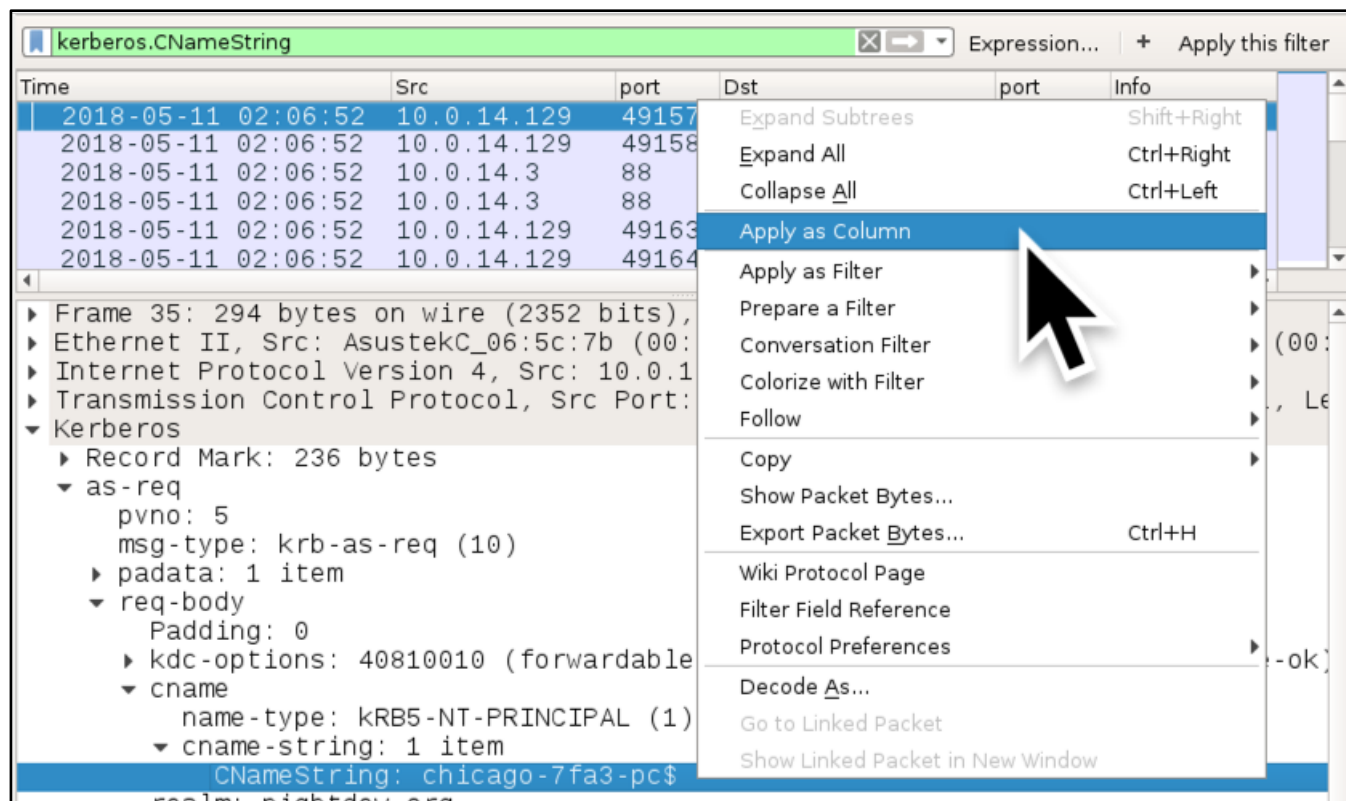
The image shows a Wireshark packet capture window with the filter 'kerberos.CNameString' applied. The packet list shows 18 packets, all of which are Kerberos messages. The columns displayed are Time, Src, port, Dst, port, and Info. The packets are filtered to show only those where the CNameString is '10.0.14.3'.

Time	Src	port	Dst	port	Info
2018-05-11 02:06:52	10.0.14.129	49157	10.0.14.3	88	AS-REQ
2018-05-11 02:06:52	10.0.14.129	49158	10.0.14.3	88	AS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49158	AS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49159	TGS-REP
2018-05-11 02:06:52	10.0.14.129	49163	10.0.14.3	88	AS-REQ
2018-05-11 02:06:52	10.0.14.129	49164	10.0.14.3	88	AS-REQ
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49164	AS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49165	TGS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49167	TGS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49169	TGS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49174	TGS-REP
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49175	TGS-REP
2018-05-11 02:06:58	10.0.14.129	49179	10.0.14.3	88	AS-REQ
2018-05-11 02:06:58	10.0.14.129	49180	10.0.14.3	88	AS-REQ
2018-05-11 02:06:58	10.0.14.3	88	10.0.14.129	49180	AS-REP
2018-05-11 02:06:58	10.0.14.3	88	10.0.14.129	49181	TGS-REP
2018-05-11 02:07:29	10.0.14.129	49183	10.0.14.3	88	AS-REQ

Shown above: Filtering on **Kerberos.CNameString** in Wireshark.

2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Next, you'll need to create a custom column in Wireshark to show the CNameString values. Select any of the frames in the display and go to the frame details section. Expand the sections until you get to the CNameString value as shown below. When you do, you can right-click on the value and "Apply as Column".

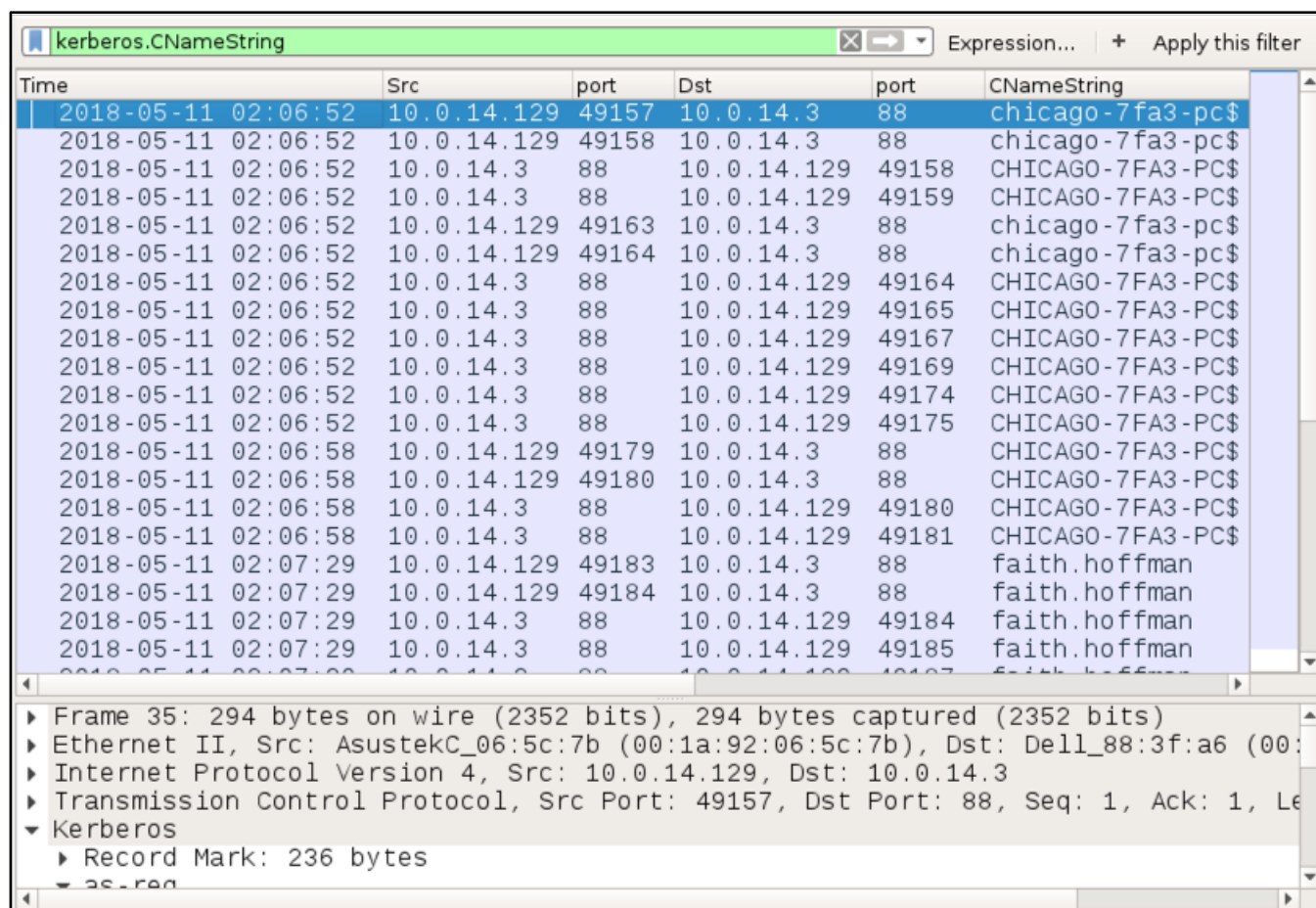


Shown above: Finding the **CNameString** value in the frame details and applying as a column.

After that, you should see a new column named CNameString that has the values seen in Kerberos traffic. In this case, we know the domain controller is 10.0.14.3 (it was provided in the exercise scenario), and the only other IP address is 10.0.14.129.

Looking through the traffic, we can correlate the IP address with the MAC address, host name, and Windows user account name as shown in the next image.

2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS



Time	Src	port	Dst	port	CNameString
2018-05-11 02:06:52	10.0.14.129	49157	10.0.14.3	88	chicago-7fa3-pc\$
2018-05-11 02:06:52	10.0.14.129	49158	10.0.14.3	88	chicago-7fa3-pc\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49158	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49159	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.129	49163	10.0.14.3	88	chicago-7fa3-pc\$
2018-05-11 02:06:52	10.0.14.129	49164	10.0.14.3	88	chicago-7fa3-pc\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49164	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49165	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49167	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49169	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49174	CHICAGO-7FA3-PC\$
2018-05-11 02:06:52	10.0.14.3	88	10.0.14.129	49175	CHICAGO-7FA3-PC\$
2018-05-11 02:06:58	10.0.14.129	49179	10.0.14.3	88	CHICAGO-7FA3-PC\$
2018-05-11 02:06:58	10.0.14.129	49180	10.0.14.3	88	CHICAGO-7FA3-PC\$
2018-05-11 02:06:58	10.0.14.3	88	10.0.14.129	49180	CHICAGO-7FA3-PC\$
2018-05-11 02:06:58	10.0.14.3	88	10.0.14.129	49181	CHICAGO-7FA3-PC\$
2018-05-11 02:07:29	10.0.14.129	49183	10.0.14.3	88	faith.hoffman
2018-05-11 02:07:29	10.0.14.129	49184	10.0.14.3	88	faith.hoffman
2018-05-11 02:07:29	10.0.14.3	88	10.0.14.129	49184	faith.hoffman
2018-05-11 02:07:29	10.0.14.3	88	10.0.14.129	49185	faith.hoffman

Frame 35: 294 bytes on wire (2352 bits), 294 bytes captured (2352 bits)

Ethernet II, Src: AsustekC_06:5c:7b (00:1a:92:06:5c:7b), Dst: Dell_88:3f:a6 (00:11:32:88:3f:a6)

Internet Protocol Version 4, Src: 10.0.14.129, Dst: 10.0.14.3

Transmission Control Protocol, Src Port: 49157, Dst Port: 88, Seq: 1, Ack: 1, Len: 236

Kerberos

Record Mark: 236 bytes

Shown above: The resulting Wireshark display, where you can correlate the IP address with a host name, user account name, and MAC address.

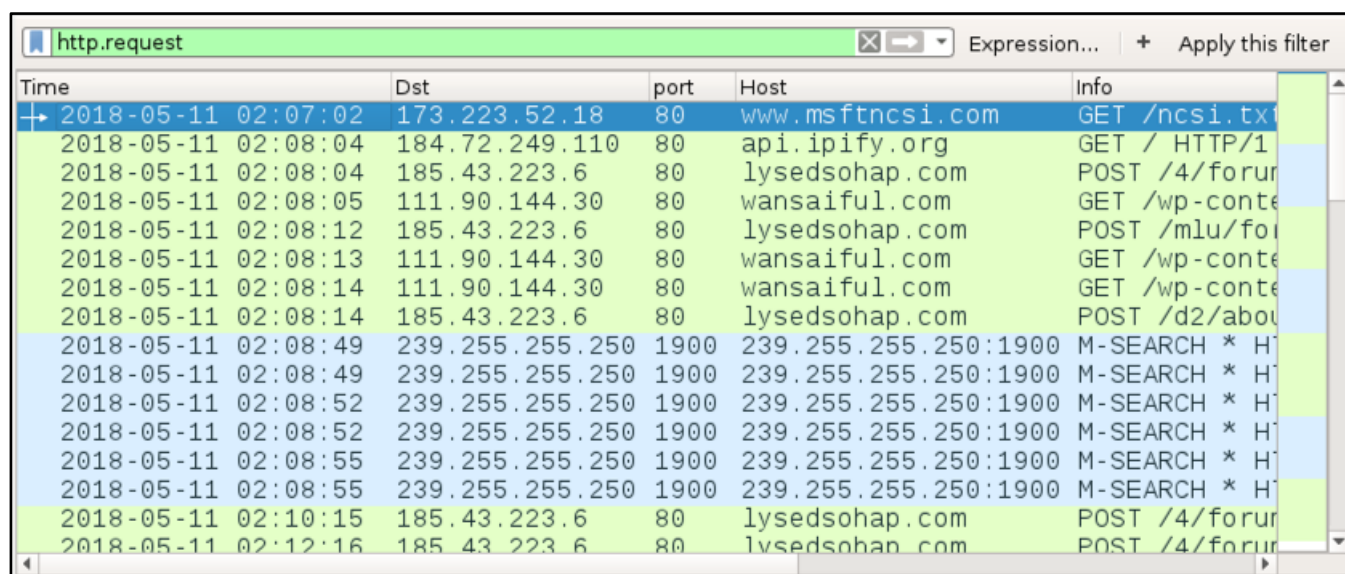
What is the infection traffic? When investigating suspicious network traffic, I usually filter on **http.request** and see what comes up. Of note, in normal investigations, you'll find a great deal of HTTP and HTTPS (and other) traffic from a normal Windows host.

However, these exercise pcaps generally tend to have very little other traffic--especially this exercise pcap. In it, you'll find very little traffic other than that related to the infection (I'm not counting the normal NBNS, SMB, Kerberos, and other internal network traffic associated with a Windows host in an Active Directory environment).

In the next image, you'll find several HTTP request. Ignore the one for www.msftncsi.com, which is normal network traffic seen shortly after a Windows host first boots up and logs into an AD environment. There's also HTTP traffic to UDP port 1900, which is also normally seen in examples of Windows network traffic.

Several of these HTTP requests are to **lysedsohap.com**. And three of them are to **wansaiful.com**. Let's see what a Google search shows on those two domains.

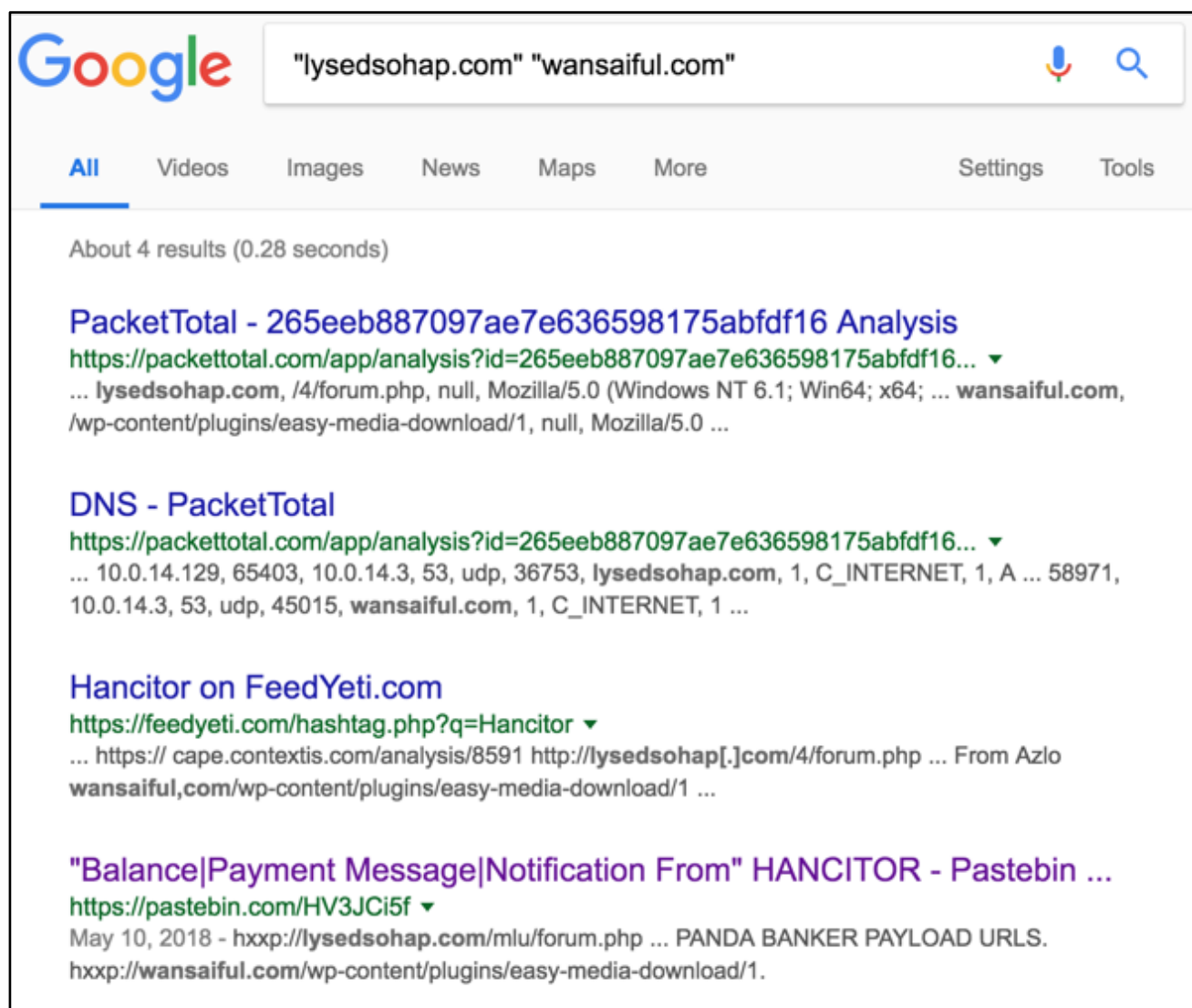
2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS



The image shows a Wireshark packet capture window with the filter 'http.request' applied. The packet list table contains 16 entries, all of which are HTTP requests. The first entry is a GET request to www.msftncsi.com. The next four entries are POST requests to lysedsohap.com and wansaiful.com. The next six entries are M-SEARCH requests to 239.255.255.250:1900. The last two entries are POST requests to lysedsohap.com. The packet details pane on the right shows the structure of the selected packet, including Ethernet II, Internet Protocol Version 4, and Hypertext Transfer Protocol.

Time	Dst	port	Host	Info
2018-05-11 02:07:02	173.223.52.18	80	www.msftncsi.com	GET /ncsi.txt
2018-05-11 02:08:04	184.72.249.110	80	api.ipify.org	GET / HTTP/1.1
2018-05-11 02:08:04	185.43.223.6	80	lysedsohap.com	POST /4/forum.php
2018-05-11 02:08:05	111.90.144.30	80	wansaiful.com	GET /wp-content/plugins/easy-media-download/1
2018-05-11 02:08:12	185.43.223.6	80	lysedsohap.com	POST /mlu/forum.php
2018-05-11 02:08:13	111.90.144.30	80	wansaiful.com	GET /wp-content/plugins/easy-media-download/1
2018-05-11 02:08:14	111.90.144.30	80	wansaiful.com	GET /wp-content/plugins/easy-media-download/1
2018-05-11 02:08:14	185.43.223.6	80	lysedsohap.com	POST /d2/about
2018-05-11 02:08:49	239.255.255.250	1900	239.255.255.250:1900	M-SEARCH * HTTP/1.1
2018-05-11 02:08:49	239.255.255.250	1900	239.255.255.250:1900	M-SEARCH * HTTP/1.1
2018-05-11 02:08:52	239.255.255.250	1900	239.255.255.250:1900	M-SEARCH * HTTP/1.1
2018-05-11 02:08:52	239.255.255.250	1900	239.255.255.250:1900	M-SEARCH * HTTP/1.1
2018-05-11 02:08:55	239.255.255.250	1900	239.255.255.250:1900	M-SEARCH * HTTP/1.1
2018-05-11 02:08:55	239.255.255.250	1900	239.255.255.250:1900	M-SEARCH * HTTP/1.1
2018-05-11 02:10:15	185.43.223.6	80	lysedsohap.com	POST /4/forum.php
2018-05-11 02:12:16	185.43.223.6	80	lysedsohap.com	POST /4/forum.php

Shown above: The Wireshark display when filtering on **http.request**.

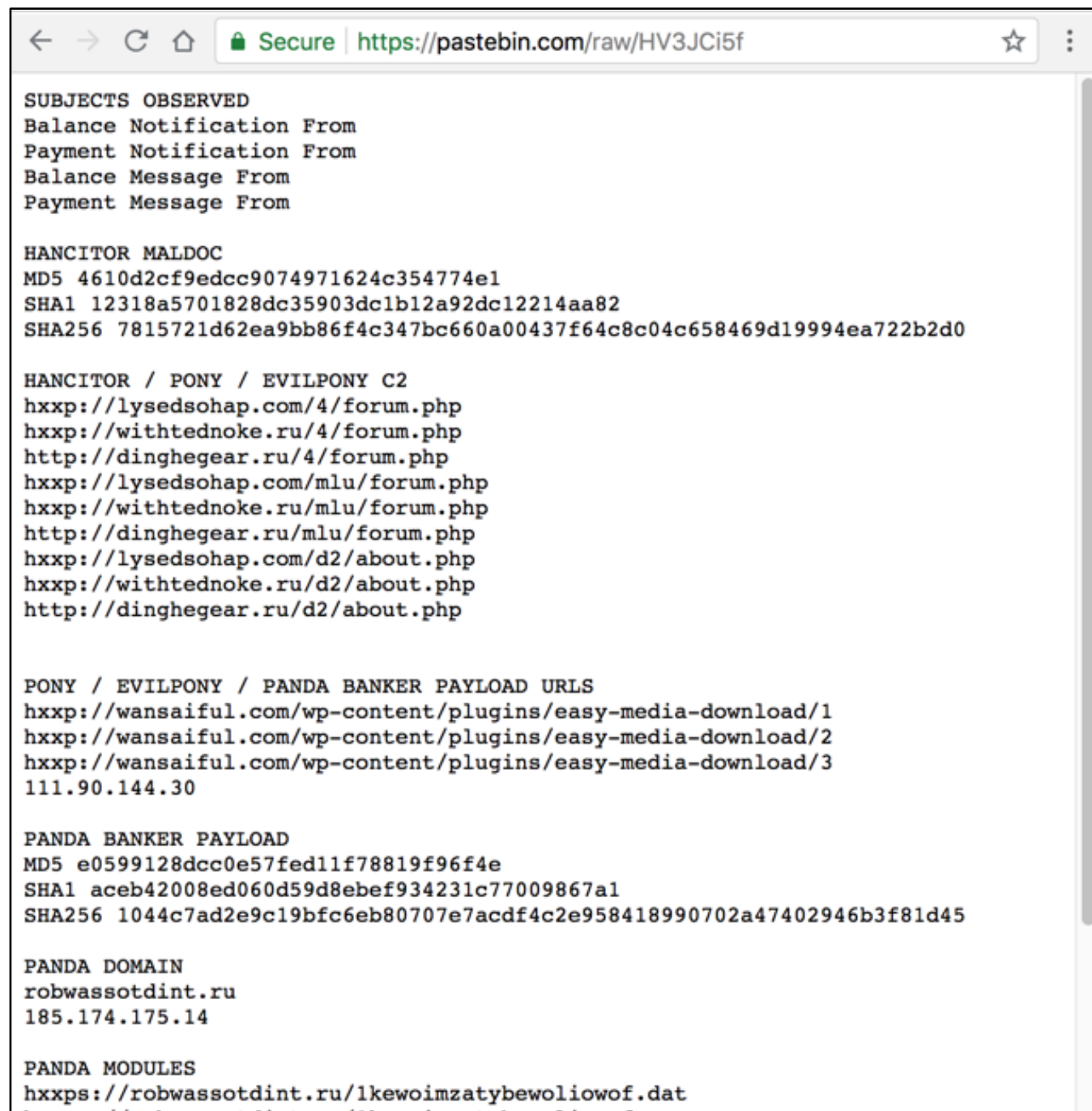


The image shows a Google search results page for the query "lysedsohap.com" "wansaiful.com". The search bar at the top contains the query. Below the search bar, there are tabs for "All", "Videos", "Images", "News", "Maps", and "More". The "All" tab is selected. The search results show "About 4 results (0.28 seconds)". The first result is "PacketTotal - 265eeb887097ae7e636598175abfdf16 Analysis" with a link to https://packettotal.com/app/analysis?id=265eeb887097ae7e636598175abfdf16... The second result is "DNS - PacketTotal" with a link to https://packettotal.com/app/analysis?id=265eeb887097ae7e636598175abfdf16... The third result is "Hancitor on FeedYeti.com" with a link to https://feedyeti.com/hashtag.php?q=Hancitor... The fourth result is "'Balance|Payment Message|Notification From' HANCITOR - Pastebin ..." with a link to https://pastebin.com/HV3JCi5f... The search results also show some additional information, such as the user agent "Mozilla/5.0 (Windows NT 6.1; Win64; x64; ...)" and the IP address "10.0.14.129, 65403, 10.0.14.3, 53, udp, 36753, lysedsohap.com, 1, C_INTERNET, 1, A ... 58971, 10.0.14.3, 53, udp, 45015, wansaiful.com, 1, C_INTERNET, 1 ...".

Shown above: Google results when searching on the two domains.

2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Google results include the PacketTotal analysis of this exercise pcap. Unfortunately that doesn't show anything useful for identification. However, you should find the results of a Pastebin link that talks about Hancitor. The search results show some of the same URLs as found in our pcap. Go to that Pastebin link to see more details.

A screenshot of a web browser window. The address bar shows a "Secure" connection to "https://pastebin.com/raw/HV3JCi5f". The page content is a text-based list of observed subjects and related information. It includes sections for "SUBJECTS OBSERVED", "HANCITOR MALDOC" with MD5, SHA1, and SHA256 hashes, "HANCITOR / PONY / EVILPONY C2" with various HTTP and HTTPS URLs, "PONY / EVILPONY / PANDA BANKER PAYLOAD URLS" with more URLs, "PANDA BANKER PAYLOAD" with hashes, "PANDA DOMAIN" with a domain and IP, and "PANDA MODULES" with a file path.

```
SUBJECTS OBSERVED
Balance Notification From
Payment Notification From
Balance Message From
Payment Message From

HANCITOR MALDOC
MD5 4610d2cf9edcc9074971624c354774e1
SHA1 12318a5701828dc35903dclb12a92dc12214aa82
SHA256 7815721d62ea9bb86f4c347bc660a00437f64c8c04c658469d19994ea722b2d0

HANCITOR / PONY / EVILPONY C2
hxxp://lysedsohap.com/4/forum.php
hxxp://withtednoke.ru/4/forum.php
http://dinghegear.ru/4/forum.php
hxxp://lysedsohap.com/mlu/forum.php
hxxp://withtednoke.ru/mlu/forum.php
http://dinghegear.ru/mlu/forum.php
hxxp://lysedsohap.com/d2/about.php
hxxp://withtednoke.ru/d2/about.php
http://dinghegear.ru/d2/about.php

PONY / EVILPONY / PANDA BANKER PAYLOAD URLS
hxxp://wansaiful.com/wp-content/plugins/easy-media-download/1
hxxp://wansaiful.com/wp-content/plugins/easy-media-download/2
hxxp://wansaiful.com/wp-content/plugins/easy-media-download/3
111.90.144.30

PANDA BANKER PAYLOAD
MD5 e0599128dcc0e57fed11f78819f96f4e
SHA1 aceb42008ed060d59d8ebef934231c77009867a1
SHA256 1044c7ad2e9c19bfc6eb80707e7acdf4c2e958418990702a47402946b3f81d45

PANDA DOMAIN
robwassotdint.ru
185.174.175.14

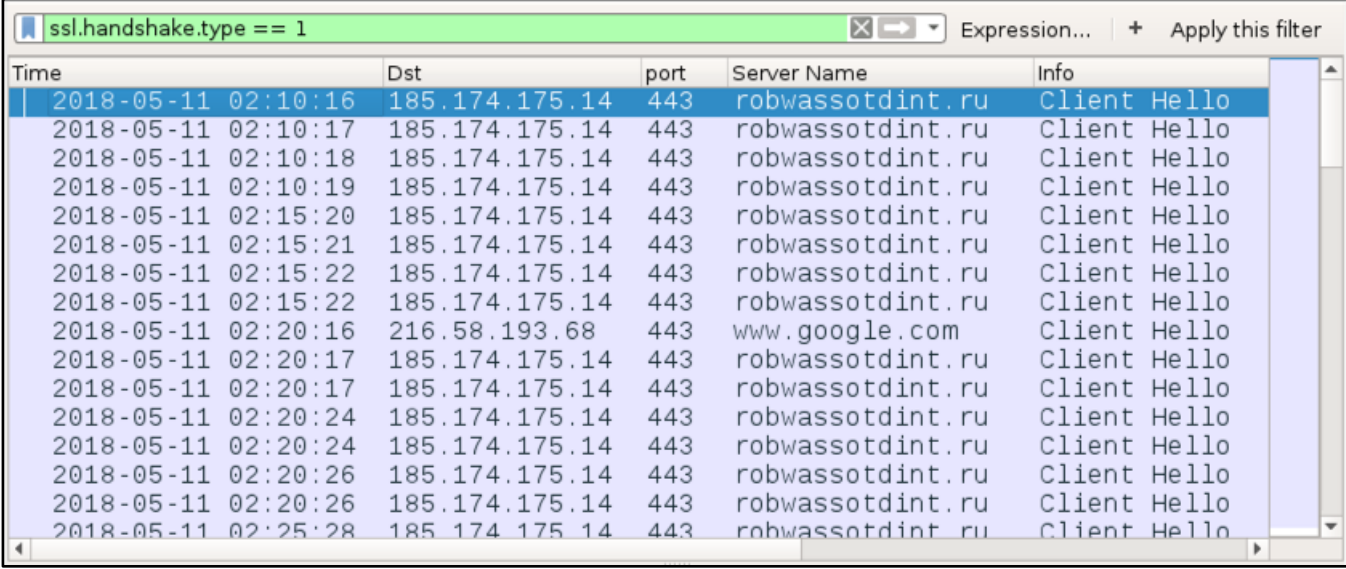
PANDA MODULES
hxxps://robwassotdint.ru/1kewoimzatybewoliowof.dat
```

Shown above: The Pastebin link from Google search results. It has Hancitor information.

In the Pastebin post shows many of the same URLs as seen in this exercise pcap, and it has all of the related Hancitor information. While we cannot confirm the exact file hashes based on our pcap, we can say this infection traffic is definitely related to Hancitor and Zeus Panda Banker.

2018-05-11 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Of note, if you filter on `ssl.handshake.type == 1`, you'll find the Zeus Panda Banker domain ***robwassotdint.ru*** in the pcap.

A screenshot of the Wireshark network protocol analyzer interface. The top filter bar shows the expression 'ssl.handshake.type == 1'. Below the filter bar, a list of network packets is displayed. The first 17 packets are highlighted in blue, indicating they match the filter. These packets are all 'Client Hello' messages to the domain 'robwassotdint.ru' on port 443. The 18th packet is a 'Client Hello' to 'www.google.com' on port 443, which does not match the filter. The table has columns for Time, Dst, port, Server Name, and Info.

Time	Dst	port	Server Name	Info
2018-05-11 02:10:16	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:10:17	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:10:18	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:10:19	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:15:20	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:15:21	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:15:22	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:15:22	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:20:16	216.58.193.68	443	www.google.com	Client Hello
2018-05-11 02:20:17	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:20:17	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:20:24	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:20:24	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:20:26	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:20:26	185.174.175.14	443	robwassotdint.ru	Client Hello
2018-05-11 02:25:28	185.174.175.14	443	robwassotdint.ru	Client Hello

Shown above: Filtering on `ssl.handshake.type == 1` should reveal the Zeus Panda Banker domain.

Since we cannot confirm the file hashes based on the pcap, you probably shouldn't include them in the incident report. There is very little public documentation other than the Pastebin link on this. However, that should be enough to identify the malware for this infection traffic. Feel free to use "probable" in the executive summary when identifying the malware responsible for this infection.